

Vulnerability Assessment Report

1st January 20XX

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. NIST SP 800-30 Rev. 1 is used to guide the risk analysis of the information system.

Purpose

Consider the following questions to help you write:

- *How is the database server valuable to the business?*
- *Why is it important for the business to secure the data on the server?*
- *How might the server impact the business if it were disabled?*

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Outsider (Hacker)	<i>Conduct Denial Of Service (DoS) attacks: sending automated, excessive requests to overwhelm the system</i>	3	3	9
Outsider (Hacker)	<i>Obtain sensitive information via exfiltration: installing malicious software to locate and acquire sensitive information</i>	2	3	6
Standard user (Employee)	<i>Alter/Delete Critical Information: purposefully or accidentally altering data critical to operations</i>	2	2	4

Approach

My approach focused on the primary risks associated with a database that has been publicly accessible for three years. I prioritized the Outsider (Hacker) threat source because public exposure makes DoS attacks and Exfiltration highly likely events that would result in catastrophic financial loss.

Remediation Strategy

Implementation of authentication, authorization, and auditing mechanisms to ensure that only authorized users access the database server. This includes using strong passwords, role-based access controls, and multi-factor authentication to limit user privileges. Encryption of data in motion using TLS instead of SSL. IP allow-listing to corporate offices to prevent random users from the internet from connecting to the database.